Cuidarte+

Aseguramiento de calidad, seguridad y cumplimiento

- EP4 · Defensa individual · ISY1102 · Sección 002v
- Antonella Cuvertino y Miriam Hammami
- Decisión sustentada: NO CERTIFICADO para producción

Un sistema clínico exige más que funcionar

Contexto, arquitectura y riesgo

- React SPA → API Express → PostgreSQL
- Administrador, médico y paciente; acceso anónimo limitado
- Prioridad: evitar exposición, privilegios indebidos y pérdida clínica

Estrategia basada en riesgos

IE2 · Seguridad y normativa desde la planificación

- Shift-Left: requisitos → riesgos → casos → evidencia
- Primero autorización y credenciales; después persistencia y rendimiento
- Entrada: ambiente aislado. Salida: cero críticos o graves abiertos

Tipos de prueba: qué comprueba cada uno

IE4 · Origen del caso e impacto

- Funcional: login válido e inválido → continuidad de acceso
- Integración: API + base + PDF → persistencia e integridad
- Seguridad: JWT, IDOR y roles → confidencialidad y privilegios
- Rendimiento: consulta y carga breve → tiempo de atención

Casos definidos y trazabilidad

IE4 / IE8 · Del requisito al defecto

- 8 casos maestros; 12 checkpoints API derivados
- RF-3.3 → CP-FUNC-003 → CP-API-007 → DEF-003
- Esperado: conservar fila. Obtenido: cero filas tras DELETE
- SQLi y WCAG completos permanecen pendientes

Herramientas y ambiente reproducible

Elección y límites de cada herramienta

- Node.js fetch + PostgreSQL: peticiones y verificación de persistencia
- SonarQube + escáner oficial: análisis estático exportado
- Docker: base aislada; navegador: evidencia visual
- Jest, DAST, JMeter sostenido y WCAG: ampliaciones pendientes

Ejecución: 12 comprobaciones reales

IE8 · Resultado, evidencia y alcance

- 6 PASS: login, inválidos, validación, IDOR, JWT y PDF
- 6 FAIL: persistencia, hash, auditoría, roles, latencia y borrado anónimo
- Evidencia: JSON por caso, CSV, consultas y capturas
- Los 5 PASS de UI del PDF anterior son antecedentes históricos

Defectos que bloquean el lanzamiento

IE4 / IE10 · Clasificación por impacto

- CRÍTICO: médico se asigna administrador (HTTP 200)
- CRÍTICO: DELETE de usuario sin sesión elimina la cuenta
- GRAVES: contraseñas, borrado físico, auditoría y latencia
- Sin correcciones ni retest de cierre: todos siguen abiertos

SonarQube: interpretar, no solo contar

IE6 · Análisis estático y comparación con criterios

- Bugs: N/D · Vulnerabilities: N/D · Hotspots: N/D · Smells: N/D
- Quality Gate: PENDIENTE · Coverage: N/D%
- Hotspot ≠ vulnerabilidad confirmada; requiere revisión
- No se confirma la SQLi del controlador inexistente del encargo

Rendimiento y privacidad

IE6 · Lo medido y la norma aplicable

- 200 solicitudes simultáneas · p95 8698 ms · objetivo <300 ms
- 0 errores HTTP; lote breve, sin acreditar estabilidad sostenida
- Ley 19.628: datos de salud y tratamiento indebido
- Ley 21.719: vigencia general desde 01-12-2026; Ley 21.663 según ámbito

Recomendaciones con evidencia

IE10 · Corregir y volver a comprobar

- 1. Autorizar antes de mutar; cambios de rol solo por administrador
- 2. Hash adaptativo, soft delete y auditoría transaccional
- 3. Retirar demoras y ejecutar retest + regresión
- 4. Completar ERS, cobertura, DAST, WCAG y carga sostenida

Dictamen: NO CERTIFICADO

La evidencia no cumple los criterios de salida

- 2 defectos críticos y 4 graves abiertos
- Reevaluar después de remediar, retestar y completar el alcance
- Expediente: informe oficial, actividades, evidencias y código
- Defensa individual: comprender cada dato y cada limitación